



நான் முதுஸ்வன்

உலக வெல்லும் இளைய தமிழகம்

IN COLLABRATION WITH
3470 HEALTHCARE PVT LTD



UNIT – 3

HIPAA RULES

What is HIPAA?

HIPAA (Health Insurance Portability and Accountability Act) is United States legislation that provides [data privacy](#) and security provisions for [safeguarding medical information](#). The law has emerged into greater prominence in recent years with the many health [data breaches](#) caused by cyber attacks and [ransom ware](#) attacks on health insurers and providers.

The federal law was signed by President Bill Clinton on Aug. 21, 1996. HIPAA overrides state laws regarding the safety of medical information, unless the state law is considered more stringent than HIPAA.

Purpose of HIPAA

- ✓ Establishing national standards for PHI
- ✓ Protecting patient confidentiality
- ✓ Preventing healthcare fraud and abuse
- ✓ Promoting healthcare access, portability, and renewability
- ✓ Ensuring compliance with federal regulations

Covered Entities under HIPAA



HIPAA contains five sections, or titles

- Title I- “Healthcare Access, Portability and Renewability”
- Title II- “Preventing Health care Fraud and Abuse; Administration Simplification; Medical Liability Reform,”
- Title III- “Tax-Related Health Provision.”
- Title IV- “Application and Enforcement of Group Health Plan Requirements,”
- Title V- “Revenue Offsets.”

Components of HIPAA

National Provider Identifier Standard: Each healthcare entity, including individuals, employers, health plans and healthcare providers, must have a unique 10-digit [National Provider Identifier](#) number, or NPI.

Transactions and Code Sets Standard: Healthcare organizations must follow a standardized mechanism for electronic data interchange ([EDI](#)) in order to submit and process insurance claims

HIPAA Privacy Rule: [The HIPAA Privacy Rule](#) Protects patients' medical records and other personal health information (PHI). It gives patients the right to access and review their records, request modifications, and limit how their PHI can be shared.

.

HIPAA Security Rule: [HIPAA Security Rule](#) establishes standards for protecting the electronic PHI (ePHI) that a covered entity creates, uses, receives, or maintains.

While the Privacy Rule governs the privacy and confidentiality of all PHI, including oral, paper, and electronic, the Security Rule focuses on guidelines specific to securing *electronic* data.

HIPAA The Breach Notification Rule: The [HIPAA Breach Notification Rule](#) requires covered entities and business associates to provide notification of a breach involving unsecured PHI. A breach is any impermissible use or disclosure of PHI under the Privacy and Security Rules.

HIPAA Violations

Civil Penalties: For an individual who unknowingly violates HIPAA \$100 fine per violation with annual maximum of \$25000 for those who repeats violation. There is also \$50,000 per violation, and an annual maximum of \$1.5 million.

Criminal Penalties: For entities are covered and specified individuals who obtain or disclose individually health information willfully and knowingly: The penalty is up to \$50,000 and imprisonment up to 1 year



HIPPA Rules

1. Privacy Rule

- **Protects:** Personal health information (PHI).
- **Applies to:** Health care providers, health plans, and health care clearinghouses ("covered entities") and their business associates.
- **Key Rights:**
 - Patients can access their medical records.
 - Patients must give authorization for most non-routine uses/disclosures.
 - Entities must inform patients of their privacy rights and practices.

HIPPA Rules

2. Security Rule

- **Protects:** Electronic protected health information (ePHI).
- **Requirements:**
 - Administrative safeguards (e.g., risk assessments, workforce training).
 - Physical safeguards (e.g., facility access controls).
 - Technical safeguards (e.g., access controls, encryption).

3. Breach Notification Rule

- **Requires:**
 - Notification to affected individuals, the U.S. Department of Health and Human Services (HHS), and in some cases, the media, if a data breach occurs.
 - Must be done within 60 days of discovering the breach.

HIPPA Rules

4. Enforcement Rule

- **Describes:**
 - Investigation procedures.
 - Penalties for non-compliance.
- **Fines:** Range from \$100 to \$50,000 per violation, with an annual maximum of \$1.5 million per violation category.

5. Omnibus Rule (2013 update)

- Strengthened privacy and security protections.
- Expanded liability to business associates (e.g., cloud providers).
- Included changes from the HITECH Act (which encouraged adoption of electronic health records).



THANK YOU!